

Under the FedRAMP Moderate baseline, CA-7.1 (CA-7.1 Independent Assessment): FedRAMP Moderate Baseline · CA-7.1 · Independent Assessment Control Statement: Employ independent assessors or assessment teams to monitor the controls in the system on an ongoing basis. Supplemental Guidance: Employ independent assessors or assessment teams to monitor the controls in the system on an ongoing basis. Organizations maximize the value of control assessments by requiring that assessments be conducted by assessors with appropriate levels of independence. The level of required indep

NIST SP 800-53 Rev 5 control CA-7.4 (Risk Monitoring) summarizes the requirements for this control: CA-7.4 · Risk Monitoring Control Statement: Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Supplemental Guidance: Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Risk monitoring is informed by the establis

NIST SP 800-171 Rev 3 control 03.12.03 (03.12.03 Continuous Monitoring) is assessed by examining the following: Assessment Objectives: - a system-level continuous monitoring strategy is developed. - a system-level continuous monitoring strategy is implemented. - ongoing monitoring is included in the continuous monitoring strategy. - security assessments are included in the continuous monitoring strategy.

Control PM-9: ry planning processes. The risk executive function, led by the senior accountable official for risk management, can facilitate consistent application of the risk management strategy organization-wide. The risk management strategy can be informed by security and privacy risk-related inputs from other sources, both internal and external to the organization, to ensure that the strategy is broad-based and comprehensive. The supply chain risk management strategy described in PM-30 can also provide useful inputs to the organization- wide risk management strategy. Related Controls: AC-1, AU-1, AT-1, CA-1, CA-2, CA-5, CA-6, CA-7, CM-1, CP-1, IA-1, IR-1, MA-1,

NIST SP 800-171 Rev 3 control 03.12.03 (03.12.03 Continuous Monitoring) requires organizations to implement the following: 03.12.03 · Continuous Monitoring Supplemental Guidance: Continuous monitoring at the system level facilitates ongoing awareness of the system security posture to support risk management decisions. The terms continuous and ongoing imply that organizations assess and monitor their systems at a frequency that is sufficient to support risk-based decisions. Different types of security requirements may require different monitoring frequencies. Assessment Objectives: - a system-level continuous monit For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.12.03.

Under the FedRAMP High baseline, CA-2.2 (CA-2.2 Specialized Assessments): FedRAMP High Baseline · CA-2.2 · Specialized Assessments Control Statement: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Supplemental Guidance: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Organizations can conduct specialized assessments, including verification and validation, system monitoring, inside

NIST SP 800-53 Rev 5 control CA-9.1 (Compliance Checks) summarizes the requirements for this control: CA-9.1 · Compliance Checks Control Statement: Perform security and privacy compliance checks on constituent system components prior to the establishment of the internal connection. Supplemental Guidance: Perform security and privacy compliance checks on constituent system components prior to the establishment of the internal connection. Compliance checks include verification of the relevant baseline configuration.

Under the FedRAMP Moderate baseline, CA-8.2 (CA-8.2 Red Team Exercises): FedRAMP Moderate Baseline · CA-8.2 · Red Team Exercises Control Statement: Employ the following red-team exercises to simulate attempts by adversaries to compromise organizational systems in accordance with applicable rules of engagement: [organization-defined parameter]. Supplemental Guidance: Employ the following red-team exercises to simulate attempts by adversaries to compromise organizational systems in accordance with applicable rules of engagement: [organization-defined parameter]. Red

NIST SP 800-53 Rev 5 control CA-1 (Policy and Procedures) summarizes the requirements for this control: CA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] assessment, authorization, and monitoring policy that: 2. Procedures to facilitate the implementation of the assessment, authorization, and monitoring policy and the associated assessment, authorization, and monitoring controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination

NIST SP 800-171 Rev 3 control 03.12.03 (03.12.03 Continuous Monitoring) falls under the Security Assessment and Monitoring family. 03.12.03 · Continuous Monitoring Supplemental Guidance: Continuous monitoring at the system level facilitates ongoing awareness of the system security posture to support risk management decisions. The terms continuous and ongoing imply that organizations assess and monitor their systems at a frequency that is sufficient to support risk-based decisions. Different types of security requirements may require different monitoring frequencies. Assessment Objectives: - a system-level continuous monitor Supplemental Guidance: Continuous monitoring at the system level facilitates ongoing awareness of the system security posture to support risk management decisions. The terms continuous and ongoing imply that organizations assess and monitor their systems at a frequency that is sufficient to support risk-based decisions. Different types of security requirements may require different monitoring frequencies.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt) REFERENCES Source Control: CA-02(01) 03.1 2.03E Risk Monitoring Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes effectiveness monitoring, compliance monitoring, change monitoring. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 DISCUSSION 1707

NIST SP 800-171 Rev 3 control 03.12.02 (03.12.02 Plan of Action and Milestones) falls under the Security Assessment and Monitoring family. Control Statement: SR-03.12.02.a Develop a plan of action and milestones for the system: SR-03.12.02.a.01 To document the planned remediation actions to correct weaknesses or deficiencies noted during security assessments and SR-03.12.02.a.02 To reduce or eliminate known system vulnerabilities. SR-03.12.02.b Update the existing plan of action and milestones based on the findings from: SR-03.12.02.b.01 Security assessments, SR-03.12.02.b.02 Audits or reviews, and SR-03.12.02.b.03 Continuous monitoring activities. Supplemental Guidance: Plans of action and milestones (POAMs) are important documents in organizational security programs. Organizations use POAMs to describe how unsatisfied security requirements will be met and how planned mitigations will be implemented. Organizations can document system security plans and POAMs as separate or combined documents in any format. Federal agencies may consider system security plans and POAMs as inputs to risk-based decisions on whether to process, store, or trans

Under the FedRAMP Low baseline, CA-9 (CA-9 Internal System Connections): FedRAMP Low Baseline · CA-9 · Internal System Connections Control Statement: a. Authorize internal connections of [organization-defined parameter] to the system; b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated; c. Terminate internal system connections after [organization-defined parameter] ; and d. Review [organization-defined parameter] the continued need for each internal connection. S

CA-6.2 · Joint Authorization · Inter-organization Control Statement: Employ a joint authorization process for the system that includes multiple authorizing officials with at least one authorizing official from an organization external to the organization conducting the authorization. Supplemental Guidance: Employ a joint authorization process for the system that includes multiple authorizing officials with at least one authorizing official from an organization external to the organization conducting the authorization. Assigning multiple authorizing officials, at least one of whom comes from an external organization, to serve as co-authorizing officials for the system increases the level of independence in the risk-based decision-making process. It implements the concepts of separation of duties and dual authorization as applied to the system authorization process. Employing authorizing officials from external organizations to supplement the authorizing official from the organization that owns or hosts the system may be necessary when the external organizations have a vested interest or equities in the outcome of the authorization decision. The inter-organization joint authorization process is relevant and appropriate for connected systems,

shared systems or services, and systems with multiple information owners. The authorizing officials from the external organizations are key stakeholders of the system undergoing authorization.

CA-3.7 · Transitive Information Exchanges Control Statement: (a) Identify transitive (downstream) information exchanges with other systems through the systems identified in [CA-3a](#ca-3_smt.a) ; and (b) Take measures to ensure that transitive (downstream) information exchanges cease when the controls on identified transitive (downstream) systems cannot be verified or validated. Supplemental Guidance: (a) Identify transitive (downstream) information exchanges with other systems through the systems identified in [CA-3a](#ca-3_smt.a) ; and (b) Take measures to ensure that transitive (downstream) information exchanges cease when the controls on identified transitive (downstream) systems cannot be verified or validated. Transitive or "downstream" information exchanges are information exchanges between the system or systems with which the organizational system exchanges information and other systems. For mission-essential systems, services, and applications, including high value assets, it is necessary to identify such information exchanges. The transparency of the controls or protection measures in place in such downstream systems connected directly or indirectly to organizational systems is essential to understanding the security and privacy risks resulting from those information exchanges. Organizational systems can inherit risk from downstream systems through transitive connections and information exchanges, which can make the organizational systems more susceptible to threats, hazards, and adverse impacts.

Under the FedRAMP Moderate baseline, CA-1 (CA-1 Policy and Procedures): FedRAMP Moderate Baseline · CA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] assessment, authorization, and monitoring policy that: 2. Procedures to facilitate the implementation of the assessment, authorization, and monitoring policy and the associated assessment, authorization, and monitoring controls; b. Designate an [organization-defined parameter] to manage the development, do

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Security Assessment and Monitoring 3.12.1 Security Requirements Assessment Assess the security requirements for the system and its environment of operation [Assignment: organization-defined frequency] (03.12.01) to determine if the requirements have been satisfied. Related Controls: CA-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.12.01 [Assignment: organization- defined frequency] at least every 12 months, or when there are significant1 incidents or significant1 changes to risks

NIST SP 800-53 Rev 5 control CA-6 (Authorization) is assessed by examining, interviewing, and testing: CA-6 · Authorization Control Statement: a. Assign a senior official as the authorizing official for the system; b. Assign a senior official as the authorizing official for common controls available for inheritance by organizational systems; c. Ensure that the authorizing official for the system, before commencing operations: 1. Accepts the use of common controls inherited by the system; and 2. Authorizes the system to operate; d. Ensure that the authorizing official for common controls auth

NIST SP 800-53 Rev 5 control CA-9 (Internal System Connections) is defined as follows: CA-9 · Internal System Connections Control Statement: a. Authorize internal connections of [organization-defined parameter] to the system; b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated; c. Terminate internal system connections after [organization-defined parameter] ; and d. Review [organization-defined parameter] the continued need for each internal connection. Supplemental Guidance: a. Authorize internal connections of [organization-defined parameter] to the system; b. Document, for

Control CA-1: rocedures. Security and privacy program policies and procedures at the organization level are preferable, in general, and may obviate the need for mission- or system- specific policies and procedures. The policy can be included as part of the general security and privacy policy or be represented by multiple policies that reflect the complex nature of organizations. Procedures can be established for security and privacy programs, for mission or business processes, and for systems, if needed. Procedures describe how the policies or controls are implemented and can be directed at the individual or role that is the object of the procedure. Procedures can be documented in system security and privacy plans or in one or more separate documents. Events that may precipitate an update to assessment, authorization, and monitoring policy and procedures include assessment or

audit findings, security incidents or breaches, or changes in applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Simply restating controls does not constitute an organizational policy or procedure. Related Controls: PM-9, PS-8, SI-12. Control Enhancements: None. CHAPTER THREE PAGE 83 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53>
r 5 l . NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

References: [OMB A-130], [SP 800-12], [SP 800-30], [SP 800-37], [SP 800-39], [SP 800-53A], [SP 800-100], [SP 800-137], [SP 800-137A], [IR 8062].

NIST SP 800-53 Rev 5 control CA-3 (Information Exchange) is assessed by examining, interviewing, and testing: CA-3 · Information Exchange Control Statement: a. Approve and manage the exchange of information between the system and other systems using [organization-defined parameter]; b. Document, as part of each exchange agreement, the interface characteristics, security and privacy requirements, controls, and responsibilities for each system, and the impact level of the information communicated; and c. Review and update the agreements [organization-defined parameter]. Supplemental Guidance: a. Approve

Under the FedRAMP Moderate baseline, CA-9 (CA-9 Internal System Connections): FedRAMP Moderate Baseline · CA-9 · Internal System Connections Control Statement: a. Authorize internal connections of [organization-defined parameter] to the system; b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated; c. Terminate internal system connections after [organization-defined parameter] ; and d. Review [organization-defined parameter] the continued need for each internal connectio

NIST SP 800-53 Rev 5 control CA-3 (Information Exchange): CA-3 · Information Exchange Control Statement: a. Approve and manage the exchange of information between the system and other systems using [organization-defined parameter]; b. Document, as part of each exchange agreement, the interface characteristics, security and privacy requirements, controls, and responsibilities for each system, and the impact level of the information communicated; and c. R

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: CA-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.12.01 [Assignment: organization- defined frequency] at least every 12 months, or when there are significant1 incidents or significant1 changes to risks Security Assessment and Monitoring 3.12.5 Exchange of Controlled Unclassified Information (CUI) a. Approve and manage the exchange of CUI between the system and other systems using [Selection (one or more): interconnection security agreements; information exchange security agreements; memoranda of understanding or agreement; service-level agreements; user agreements; non- disclosure agreements; other types of agreements] (03.12.05.a). b. Document interface characteristics, security requirements, and responsibilities for each system as part of th

NIST SP 800-53 Rev 5 control CA-7.6 (Automation Support for Monitoring) summarizes the requirements for this control: CA-7.6 · Automation Support for Monitoring Control Statement: Ensure the accuracy, currency, and availability of monitoring results for the system using [organization-defined parameter]. Supplemental Guidance: Ensure the accuracy, currency, and availability of monitoring results for the system using [organization-defined parameter]. Using automated tools for monitoring helps to maintain the accuracy, currency, and availability of monitoring information which in turns helps to increase the leve

NIST SP 800-171 Rev 3 control 03.12.02 (03.12.02 Plan of Action and Milestones) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Security Assessment and Monitoring (CA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP High baseline, CA-2 (CA-2 Control Assessments): FedRAMP High Baseline · CA-2 · Control Assessments Control Statement: a. Select the appropriate assessor or assessment team for the type of assessment to be conducted; b. Develop a control assessment plan that describes the scope of the assessment including: 1. Controls and control enhancements under assessment; 2.

Assessment procedures to be used to determine control effectiveness; and 3. Assessment environment, assessment team, and assessment roles and responsibilities; c. Ensure the co

NIST SP 800-53 Rev 5 control CA-8.3 (Facility Penetration Testing) is assessed by examining, interviewing, and testing: CA-8.3 · Facility Penetration Testing Control Statement: Employ a penetration testing process that includes [organization-defined parameter] [organization-defined parameter] attempts to bypass or circumvent controls associated with physical access points to the facility. Supplemental Guidance: Employ a penetration testing process that includes [organization-defined parameter] [organization-defined parameter] attempts to bypass or circumvent controls associated with physical access points to th

NIST SP 800-53 Rev 5 control CA-2.3 (Leveraging Results from External Organizations) is assessed by examining, interviewing, and testing: CA-2.3 · Leveraging Results from External Organizations Control Statement: Leverage the results of control assessments performed by [organization-defined parameter] on [organization-defined parameter] when the assessment meets [organization-defined parameter]. Supplemental Guidance: Leverage the results of control assessments performed by [organization-defined parameter] on [organization-defined parameter] when the assessment meets [organization-defined parameter]. Organizations may rely on co

NIST SP 800-53 Rev 5 control CA-9.1 (Compliance Checks) is assessed by examining, interviewing, and testing: CA-9.1 · Compliance Checks Control Statement: Perform security and privacy compliance checks on constituent system components prior to the establishment of the internal connection. Supplemental Guidance: Perform security and privacy compliance checks on constituent system components prior to the establishment of the internal connection. Compliance checks include verification of the relevant baseline configuration.

NIST SP 800-171 Rev 3 control 03.12.05 (03.12.05 Information Exchange) is assessed by examining the following: Assessment Objectives: - the exchange of CUI between the system and other systems is approved using [organization-defined parameter]. - the exchange of CUI between the system and other systems is managed using [organization-defined parameter]. - interface characteristics for each system are documented as part of the exchange agreements. - security requirements for each system are documented as part of the exchange agreements. - responsibilities for each system are documented as part of the exchange agreements. - exchange agreements are reviewed [organization-defined parameter] . - exchange agr

Under the FedRAMP High baseline, CA-7.1 (CA-7.1 Independent Assessment): FedRAMP High Baseline · CA-7.1 · Independent Assessment Control Statement: Employ independent assessors or assessment teams to monitor the controls in the system on an ongoing basis. Supplemental Guidance: Employ independent assessors or assessment teams to monitor the controls in the system on an ongoing basis. Organizations maximize the value of control assessments by requiring that assessments be conducted by assessors with appropriate levels of independence. The level of required independe

NIST SP 800-53 Rev 5 control CA-2.1 (Independent Assessors) is defined as follows: CA-2.1 · Independent Assessors Control Statement: Employ independent assessors or assessment teams to conduct control assessments. Supplemental Guidance: Employ independent assessors or assessment teams to conduct control assessments. Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of systems. Impartiality means that assessors are free from any perceived or actual conflicts of interest regarding the development, operation, sustainment, or management of the systems under assessment or the determination of control effectiveness. To achieve

NIST SP 800-53 Rev 5 control CA-2 (Control Assessments) summarizes the requirements for this control: CA-2 · Control Assessments Control Statement: a. Select the appropriate assessor or assessment team for the type of assessment to be conducted; b. Develop a control assessment plan that describes the scope of the assessment including: 1. Controls and control enhancements under assessment; 2. Assessment procedures to be used to determine control effectiveness; and 3. Assessment environment, assessment team, and assessment roles and responsibilities; c. Ensure the control assessment plan is

NIST SP 800-171 Rev 3 control 03.12.03 (03.12.03 Continuous Monitoring) is assessed by examining the following: Assessment Objectives: - a system-level continuous monitoring strategy is developed. - a

system-level continuous monitoring strategy is implemented. - ongoing monitoring is included in the continuous monitoring strategy. - security assessments are included in the continuous monitoring strategy.

Under the FedRAMP High baseline, CA-3 (CA-3 Information Exchange): FedRAMP High Baseline · CA-3 · Information Exchange Control Statement: a. Approve and manage the exchange of information between the system and other systems using [organization-defined parameter]; b. Document, as part of each exchange agreement, the interface characteristics, security and privacy requirements, controls, and responsibilities for each system, and the impact level of the information communicated; and c. Review and update the agreements [organization-defined parameter]. Supplemental

NIST SP 800-171 Rev 3 control 03.12.01 (03.12.01 Security Assessment) requires organizations to implement the following: 03.12.01 · Security Assessment Supplemental Guidance: By assessing the security requirements, organizations determine whether the necessary safeguards and countermeasures are implemented correctly, operating as intended, and producing the desired outcome. Security assessments identify weaknesses in the system and provide the essential information needed to make risk-based decisions. Security assessment reports document assessment results in sufficient detail as deemed necessary by the organization. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.12.01.

03.12.01 · Security Assessment Supplemental Guidance: By assessing the security requirements, organizations determine whether the necessary safeguards and countermeasures are implemented correctly, operating as intended, and producing the desired outcome. Security assessments identify weaknesses in the system and provide the essential information needed to make risk-based decisions. Security assessment reports document assessment results in sufficient detail as deemed necessary by the organization to determine the accuracy and completeness of the reports. Security assessment results are provided to the individuals or roles appropriate for the types of assessments being conducted. Assessment Objectives: - the security requirements for the system and its environment of operation are assessed [organization-defined parameter] to determine if the requirements have been satisfied. Organization-Defined Parameters: - A.03.12.01.ODP.01: frequency

Under the FedRAMP Moderate baseline, CA-7.4 (CA-7.4 Risk Monitoring): FedRAMP Moderate Baseline · CA-7.4 · Risk Monitoring Control Statement: Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Supplemental Guidance: Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Risk monitoring

NIST SP 800-53 Rev 5 control CA-2.1 (Independent Assessors) is assessed by examining, interviewing, and testing: CA-2.1 · Independent Assessors Control Statement: Employ independent assessors or assessment teams to conduct control assessments. Supplemental Guidance: Employ independent assessors or assessment teams to conduct control assessments. Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of systems. Impartiality means that assessors are free from any perceived or actual conflicts of interest regarding the development, operation, sustainment, or m

Under the FedRAMP Moderate baseline, CA-2 (CA-2 Control Assessments): FedRAMP Moderate Baseline · CA-2 · Control Assessments Control Statement: a. Select the appropriate assessor or assessment team for the type of assessment to be conducted; b. Develop a control assessment plan that describes the scope of the assessment including: 1. Controls and control enhancements under assessment; 2. Assessment procedures to be used to determine control effectiveness; and 3. Assessment environment, assessment team, and assessment roles and responsibilities; c. Ensure th

NIST SP 800-53 Rev 5 control CA-1 (Policy and Procedures) is assessed by examining, interviewing, and testing: CA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] assessment, authorization, and monitoring policy that: 2. Procedures to facilitate the implementation of the assessment, authorization, and monitoring policy and the associated assessment, authorization, and monitoring controls; b. Designate an [organization-defined parameter] to manage the development, documentation,

and dissemination

unannounced] attempts to bypass or circumvent controls associated with physical access points to the facility. Discussion: Penetration testing of physical access points can provide information on critical vulnerabilities in the operating environments of organizational systems. Such information can be used to correct weaknesses or deficiencies in physical controls that are necessary to protect organizational systems. Related Controls: CA-2, PE-3. References: None.

NIST SP 800-53 Rev 5 control CA-9 (Internal System Connections) is assessed by examining, interviewing, and testing: CA-9 · Internal System Connections Control Statement: a. Authorize internal connections of [organization-defined parameter] to the system; b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated; c. Terminate internal system connections after [organization-defined parameter] ; and d. Review [organization-defined parameter] the continued need for each internal connection. Supplemental Guidance: a

NIST SP 800-53 Rev 5 control CA-7.5 (Consistency Analysis) summarizes the requirements for this control: CA-7.5 · Consistency Analysis Control Statement: Employ the following actions to validate that policies are established and implemented controls are operating in a consistent manner: [organization-defined parameter]. Supplemental Guidance: Employ the following actions to validate that policies are established and implemented controls are operating in a consistent manner: [organization-defined parameter]. Security and privacy controls are often added incrementally to a system. As a result, poli

Control CA-6: oing authorizations of systems based on evidence produced from implemented continuous monitoring programs. Robust continuous monitoring programs reduce the need for separate reauthorization processes. Through the employment of comprehensive continuous monitoring processes, the information contained in authorization packages (i.e., security and privacy plans, assessment reports, and plans of action and milestones) is updated on an ongoing basis. This provides authorizing officials, common control providers, and system owners with an up-to-date status of the security and privacy posture of their systems, controls, and operating environments. To reduce the cost of reauthorization, authorizing officials can leverage the results of continuous monitoring processes to the maximum extent possible as the basis for rendering reauthorization decisions.

CHAPTER THREE PAGE 89 NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Related Controls: CA-2, CA-3, CA-7, PM-9, PM-10, RA-3, SA-10, SI-12. Control Enhancements: (1) AUTHORIZATION | JOINT AUTHORIZATION · INTRA-ORGANIZATION Employ a joint authorization process for the system that includes multiple authorizing officials from the same organization conducting the authorization. Discussion: Assigning multiple authorizing officials from the same organization to serve as co-authorizing officials for the system increases the level of independence in the risk-based decision-making process. It also implements the concepts of separation of duties and dual authorization as applied to the system authorization process. The intra-organization joint authorization process is most relevant for connected systems, shared systems, and systems with multiple information owners. T h s i p u b Related Controls: AC-6.

NIST SP 800-53 Rev 5 control CA-2.2 (Specialized Assessments) is assessed by examining, interviewing, and testing: CA-2.2 · Specialized Assessments Control Statement: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Supplemental Guidance: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Organizations can conduct specialized assessments, including verification and validation, system monitoring, insider threat assessments, ma

NIST SP 800-53 Rev 5 control CA-8.1 (Independent Penetration Testing Agent or Team) is defined as follows: CA-8.1 · Independent Penetration Testing Agent or Team Control Statement: Employ an independent penetration testing agent or team to perform penetration testing on the system or system components. Supplemental Guidance: Employ an independent penetration testing agent or team to perform penetration testing on the system or system components. Independent penetration testing agents or teams are individuals or groups who conduct impartial penetration testing of

organizational systems. Impartiality implies that penetration testing agents or teams are free from perceived or actual conflicts of interest

NIST SP 800-53 Rev 5 control CA-2.2 (Specialized Assessments) summarizes the requirements for this control: CA-2.2 · Specialized Assessments Control Statement: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Supplemental Guidance: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Organizations can conduct specialized assessments, including verification and validation, system monitoring, insider threat assessments, ma

NIST SP 800-171 Rev 3 control 03.12.02 (03.12.02 Plan of Action and Milestones) is assessed by examining the following: Assessment Objectives: - a plan of action and milestones for the system is developed to document the planned remediation actions for correcting weaknesses or deficiencies noted during security assessments. - a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities. - the existing plan of action and milestones is updated based on the findings from security assessments. - the existing plan of action and milestones is updated based on the findings from continuous monitoring activities. - the existing plan of action and milestones is updated b

Under the FedRAMP Moderate baseline, CA-8.1 (CA-8.1 Independent Penetration Testing Agent or Team): FedRAMP Moderate Baseline · CA-8.1 · Independent Penetration Testing Agent or Team Control Statement: Employ an independent penetration testing agent or team to perform penetration testing on the system or system components. Supplemental Guidance: Employ an independent penetration testing agent or team to perform penetration testing on the system or system components. Independent penetration testing agents or teams are individuals or groups who conduct impartial penetration testing of organiza

NIST SP 800-171 Rev 3 control 03.12.01 (03.12.01 Security Assessment) is assessed by examining the following: Assessment Objectives: - the security requirements for the system and its environment of operation are assessed [organization-defined parameter] to determine if the requirements have been satisfied.

NIST SP 800-53 Rev 5 control CA-3.6 (Transfer Authorizations) is assessed by examining, interviewing, and testing: CA-3.6 · Transfer Authorizations Control Statement: Verify that individuals or systems transferring data between interconnecting systems have the requisite authorizations (i.e., write permissions or privileges) prior to accepting such data. Supplemental Guidance: Verify that individuals or systems transferring data between interconnecting systems have the requisite authorizations (i.e., write permissions or privileges) prior to accepting such data. To prevent unauthorized individuals and syste

NIST SP 800-53 Rev 5 control CA-2.3 (Leveraging Results from External Organizations) summarizes the requirements for this control: CA-2.3 · Leveraging Results from External Organizations Control Statement: Leverage the results of control assessments performed by [organization-defined parameter] on [organization-defined parameter] when the assessment meets [organization-defined parameter]. Supplemental Guidance: Leverage the results of control assessments performed by [organization-defined parameter] on [organization-defined parameter] when the assessment meets [organization-defined parameter]. Organizations may rely on co

Under the FedRAMP Low baseline, CA-5 (CA-5 Plan of Action and Milestones): FedRAMP Low Baseline · CA-5 · Plan of Action and Milestones Control Statement: a. Develop a plan of action and milestones for the system to document the planned remediation actions of the organization to correct weaknesses or deficiencies noted during the assessment of the controls and to reduce or eliminate known vulnerabilities in the system; and b. Update existing plan of action and milestones [organization-defined parameter] based on the findings from control assessments, independent audits

Under the FedRAMP Low baseline, CA-1 (CA-1 Policy and Procedures): FedRAMP Low Baseline · CA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] assessment, authorization, and monitoring policy that: 2. Procedures to facilitate the implementation of the assessment, authorization, and

monitoring policy and the associated assessment, authorization, and monitoring controls; b. Designate an [organization-defined parameter] to manage the development, document

Under the FedRAMP High baseline, CA-7 (CA-7 Continuous Monitoring): FedRAMP High Baseline · CA-7 · Continuous Monitoring Control Statement: Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy that includes: a. Establishing the following system-level metrics to be monitored: [organization-defined parameter]; b. Establishing [organization-defined parameter] for monitoring and [organization-defined parameter] for assessment of control effectiveness; c. On

and b. Update existing plan of action and milestones [Assignment: organization-defined frequency] based on the findings from control assessments, independent audits or reviews, and continuous monitoring activities. Discussion: Plans of action and milestones are useful for any type of organization to track planned remedial actions. Plans of action and milestones are required in authorization packages and subject to federal reporting requirements established by OMB. Related Controls: CA-2, CA-7, PM-4, PM-9, RA-7, SI-2, SI-12. CHAPTER THREE PAGE 88 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Control Enhancements: (1) PLAN OF ACTION AND MILESTONES | AUTOMATION SUPPORT FOR ACCURACY AND CURRENCY Ensure the accuracy, currency, and availability of the plan of action and milestones for the system using [Assignment: organization-defined automated mechanisms]. Discussion: Using automated tools helps maintain the accuracy, currency, and availability of the plan of action and milestones and facilitates the coordination and sharing of security and privacy information throughout the organization.

CA-2.2 · Specialized Assessments Control Statement: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Supplemental Guidance: Include as part of control assessments, [organization-defined parameter], [organization-defined parameter], [organization-defined parameter]. Organizations can conduct specialized assessments, including verification and validation, system monitoring, insider threat assessments, malicious user testing, and other forms of testing. These assessments can improve readiness by exercising organizational capabilities and indicating current levels of performance as a means of focusing actions to improve security and privacy. Organizations conduct specialized assessments in accordance with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Authorizing officials approve the assessment methods in coordination with the organizational risk executive function. Organizations can include vulnerabilities uncovered during assessments into vulnerability remediation processes. Specialized assessments can also be conducted early in the system development life cycle (e.g., during initial design, development, and unit testing).

NIST SP 800-171 Rev 3 control 03.12.05 (03.12.05 Information Exchange) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Security Assessment and Monitoring (CA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP High baseline, CA-8 (CA-8 Penetration Testing): FedRAMP High Baseline · CA-8 · Penetration Testing Control Statement: Conduct penetration testing [organization-defined parameter] on [organization-defined parameter]. Supplemental Guidance: Conduct penetration testing [organization-defined parameter] on [organization-defined parameter]. Penetration testing is a specialized type of assessment conducted on systems or individual system components to identify vulnerabilities that could be exploited by adversaries. Penetration testing goes beyond

NIST SP 800-171 Rev 3 control 03.12.03 (03.12.03 Continuous Monitoring) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Security Assessment and Monitoring (CA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

From the NIST SP 800-172 Rev 3 Final Public Draft: REFERENCES 1679 Source Control: CA-08 1680 03.1 2.02E Independent Assessors Use independent assessors or assessment teams to conduct security requirement assessments. DISCUSSION Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of systems. Impartiality means that assessors are free from any perceived or actual conflicts of interest regarding the development, operation, sustainment, or management of the systems under assessment or the determination of security requirement effectiveness. To achieve impartiality, assessors do not create a mutual or conflicting interest with the organizations where the assessments are being conducted, assess their own work, act as management or employees of the organizations they are serving, or

[Assignment: organization-defined other forms of assessment]]. Discussion: Organizations can conduct specialized assessments, including verification and validation, system monitoring, insider threat assessments, malicious user testing, and other forms of testing. These assessments can improve readiness by exercising organizational capabilities and indicating current levels of performance as a means of focusing actions to improve security and privacy. Organizations conduct specialized assessments in accordance with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Authorizing officials approve the assessment methods in coordination with the organizational risk executive function. Organizations can include vulnerabilities uncovered during assessments into vulnerability remediation processes. Specialized assessments can also be conducted early in the system development life cycle (e.g., during initial design, development, and unit testing). Related Controls: PE-3, SI-2. (3) CONTROL ASSESSMENTS | LEVERAGING RESULTS FROM EXTERNAL ORGANIZATIONS Leverage the results of control assessments performed by [Assignment: organization-defined external organization] on [Assignment: organization-defined system] when the assessment meets [Assignment: organization-defined requirements].

Under the FedRAMP High baseline, CA-2.1 (CA-2.1 Independent Assessors): FedRAMP High Baseline · CA-2.1 · Independent Assessors Control Statement: Employ independent assessors or assessment teams to conduct control assessments. Supplemental Guidance: Employ independent assessors or assessment teams to conduct control assessments. Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of systems. Impartiality means that assessors are free from any perceived or actual conflicts of interest regarding the development, oper

From the NIST SP 800-172 Rev 3 Final Public Draft: Risk monitoring is guided and informed by the established organizational risk tolerance. Effectiveness monitoring determines the ongoing effectiveness of the implemented risk response measures. Compliance monitoring verifies that required risk response measures are implemented. It also verifies that security requirements are satisfied. Change monitoring identifies changes to organizational systems and environments of operation that may affect security risk. This requirement enhances SP 800-171 requirement 03.12.03. PROTECTION STRATEGY PRA, DLO ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Expose (Detect) REFERENCES Source Control: CA-07(04) 03.1 2.04E Internal System Connections a. Authorize internal connections of [Assignment: organization-defined system component

NIST SP 800-53 Rev 5 control CA-2.1 (Independent Assessors): CA-2.1 · Independent Assessors Control Statement: Employ independent assessors or assessment teams to conduct control assessments. Supplemental Guidance: Employ independent assessors or assessment teams to conduct control assessments. Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of systems. Impartiality means that assessors are free from a

Under the FedRAMP High baseline, CA-7.4 (CA-7.4 Risk Monitoring): FedRAMP High Baseline · CA-7.4 · Risk Monitoring Control Statement: Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Supplemental Guidance: Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Risk monitoring is

Under the FedRAMP Low baseline, CA-7.4 (CA-7.4 Risk Monitoring): FedRAMP Low Baseline · CA-7.4 · Risk Monitoring Control Statement: Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Supplemental Guidance: Ensure risk monitoring is an integral

part of the continuous monitoring strategy that includes the following: (a) Effectiveness monitoring; (b) Compliance monitoring; and (c) Change monitoring. Risk monitoring is i

Under the FedRAMP High baseline, CA-8.2 (CA-8.2 Red Team Exercises): FedRAMP High Baseline · CA-8.2 · Red Team Exercises Control Statement: Employ the following red-team exercises to simulate attempts by adversaries to compromise organizational systems in accordance with applicable rules of engagement: [organization-defined parameter]. Supplemental Guidance: Employ the following red-team exercises to simulate attempts by adversaries to compromise organizational systems in accordance with applicable rules of engagement: [organization-defined parameter]. Red team

NIST SP 800-53 Rev 5 control CA-5 (Plan of Action and Milestones) is assessed by examining, interviewing, and testing: CA-5 · Plan of Action and Milestones Control Statement: a. Develop a plan of action and milestones for the system to document the planned remediation actions of the organization to correct weaknesses or deficiencies noted during the assessment of the controls and to reduce or eliminate known vulnerabilities in the system; and b. Update existing plan of action and milestones [organization-defined parameter] based on the findings from control assessments, independent audits or reviews, and contin

NIST SP 800-171 Rev 3 control 03.12.05 (03.12.05 Information Exchange) requires organizations to implement the following: Control Statement: SR-03.12.05.a Approve and manage the exchange of CUI between the system and other systems using [organization-defined parameter]. SR-03.12.05.b Document interface characteristics, security requirements, and responsibilities for each system as part of the exchange agreements. SR-03.12.05.c Review and update the exchange agreements [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.12.05.

Under the FedRAMP High baseline, CA-1 (CA-1 Policy and Procedures): FedRAMP High Baseline · CA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] assessment, authorization, and monitoring policy that: 2. Procedures to facilitate the implementation of the assessment, authorization, and monitoring policy and the associated assessment, authorization, and monitoring controls; b. Designate an [organization-defined parameter] to manage the development, docume

NIST SP 800-171 Rev 3 control 03.12.05 (03.12.05 Information Exchange) is assessed by examining the following: Assessment Objectives: - the exchange of CUI between the system and other systems is approved using [organization-defined parameter]. - the exchange of CUI between the system and other systems is managed using [organization-defined parameter]. - interface characteristics for each system are documented as part of the exchange agreements. - security requirements for each system are documented as part of the exchange agreements. - responsibilities for each system are documented as part of the exchange agreements. - exchange agreements are reviewed [organization-defined parameter] . - exchange agr

Under the FedRAMP Moderate baseline, CA-2.1 (CA-2.1 Independent Assessors): FedRAMP Moderate Baseline · CA-2.1 · Independent Assessors Control Statement: Employ independent assessors or assessment teams to conduct control assessments. Supplemental Guidance: Employ independent assessors or assessment teams to conduct control assessments. Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of systems. Impartiality means that assessors are free from any perceived or actual conflicts of interest regarding the development,

Under the FedRAMP Low baseline, CA-7 (CA-7 Continuous Monitoring): FedRAMP Low Baseline · CA-7 · Continuous Monitoring Control Statement: Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy that includes: a. Establishing the following system-level metrics to be monitored: [organization-defined parameter]; b. Establishing [organization-defined parameter] for monitoring and [organization-defined parameter] for assessment of control effectiveness; c. Ong

NIST SP 800-171 Rev 3 control 03.12.02 (03.12.02 Plan of Action and Milestones) is assessed by examining the following: Assessment Objectives: - a plan of action and milestones for the system is

developed to document the planned remediation actions for correcting weaknesses or deficiencies noted during security assessments. - a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities. - the existing plan of action and milestones is updated based on the findings from security assessments. - the existing plan of action and milestones is updated based on the findings from continuous monitoring activities. - the existing plan of action and milestones is updated b

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement is sourced to a control tailored out of the SP 1742 800-53B [13] moderate baseline in SP 800-171. P ROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: CA-09 3.13 . System and Communications Protection 03.1 3.01E H eterogeneity Employ a diverse set of information technologies for the following system components in the implementation of the system: [Assignment: organization- defined system components]. DISCUSSION Increasing the diversity of information technologies within organizational systems reduces the impact of exploitations or compromises of specific technologies. Such diversity protects against common mode failures, including those failures induced by supply chain attacks. Diversity in information tec

Under the FedRAMP Low baseline, CA-3 (CA-3 Information Exchange): FedRAMP Low Baseline · CA-3 · Information Exchange Control Statement: a. Approve and manage the exchange of information between the system and other systems using [organization-defined parameter]; b. Document, as part of each exchange agreement, the interface characteristics, security and privacy requirements, controls, and responsibilities for each system, and the impact level of the information communicated; and c. Review and update the agreements [organization-defined parameter]. Supplement

NIST SP 800-171 Rev 3 control 03.12.01 (03.12.01 Security Assessment) is assessed by examining the following: Assessment Objectives: - the security requirements for the system and its environment of operation are assessed [organization-defined parameter] to determine if the requirements have been satisfied.

NIST SP 800-53 Rev 5 control CA-7.1 (Independent Assessment) is assessed by examining, interviewing, and testing: CA-7.1 · Independent Assessment Control Statement: Employ independent assessors or assessment teams to monitor the controls in the system on an ongoing basis. Supplemental Guidance: Employ independent assessors or assessment teams to monitor the controls in the system on an ongoing basis. Organizations maximize the value of control assessments by requiring that assessments be conducted by assessors with appropriate levels of independence. The level of required independence is based on organiza

Under the FedRAMP High baseline, CA-8.1 (CA-8.1 Independent Penetration Testing Agent or Team): FedRAMP High Baseline · CA-8.1 · Independent Penetration Testing Agent or Team Control Statement: Employ an independent penetration testing agent or team to perform penetration testing on the system or system components. Supplemental Guidance: Employ an independent penetration testing agent or team to perform penetration testing on the system or system components. Independent penetration testing agents or teams are individuals or groups who conduct impartial penetration testing of organization

Under the FedRAMP High baseline, CA-9 (CA-9 Internal System Connections): FedRAMP High Baseline · CA-9 · Internal System Connections Control Statement: a. Authorize internal connections of [organization-defined parameter] to the system; b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated; c. Terminate internal system connections after [organization-defined parameter] ; and d. Review [organization-defined parameter] the continued need for each internal connection.

NIST SP 800-53 Rev 5 control CA-2.1 (Independent Assessors) summarizes the requirements for this control: CA-2.1 · Independent Assessors Control Statement: Employ independent assessors or assessment teams to conduct control assessments. Supplemental Guidance: Employ independent assessors or assessment teams to conduct control assessments. Independent assessors or assessment teams are individuals or groups who conduct impartial assessments of systems. Impartiality means that assessors are free from any perceived or actual conflicts of interest regarding the development, operation, sustainment, or m